Vulnerability Assessment Report

1st January 20XX

System Description

The server hardware consists of a powerful CPU processor and 128GB of memory. It runs on the latest version of Linux operating system and hosts a MySQL database management system. It is configured with a stable network connection using IPv4 addresses and interacts with other servers on the network. Security measures include SSL/TLS encrypted connections.

Scope

The scope of this vulnerability assessment relates to the current access controls of the system. The assessment will cover a period of three months, from June 20XX to August 20XX. NIST SP 800-30 Rev. 1 is used to guide the risk analysis of the information system.

Purpose

Consider the following questions to help you write:

- *How is the database server valuable to the business?*
- *Why is it important for the business to secure the data on the server?*
- *How might the server impact the business if it were disabled?*

The main reason for conducting this vulnerability assessment is to provide a summary or report to stakeholders of incoming threats that have been compromised, at any level, it can be at public level, or within the organization, like system administrator. Another purpose is to gather information to reduce the risk of future threat, like obtaining sensitive information.

Risk Assessment

Threat source	*Threat event*	*Likelihood*	*Severity*	*Risk*
Competitor	*Obtain sensitive information via exfiltration*	*1*	*3*	*3*
Malicious software	*Threat source installs software designed to collect (sniff) network traffic over a continued period of time.*	*2*	*3*	*3*
Hacker	*Threat source sends automated, excessive requests to overwhelm the system's operating capabilities.*	*3*	*3*	*2*

Approach

Risks considered the data storage and management methods of the business. The likelihood of a threat occurrence and the impact of these potential events were weighed against the risks to day-to-day operational needs.

The top three choices for risk assessment is because the first threat sources as competitors are possible due to other companies trying to gather resources from each other when the database is accessible in public. But the likelihood is very low compared to other threat sources.

Second threat source could be malicious software when the threat actor/hacker intentionally injects software that mimics or obtains sensitive data, or it could also be designed to collect or packet sniffing and gain knowledge of network traffic over time.

The last threat source can be hackers because they can silently perform reconnaissance and surveillance of an organization, or they can even be a part of

insider threat, like admin or someone close to admin. Overall the hackers are unpredictable when database server open to the public

Remediation Strategy

Implementation of authentication, authorization, and auditing mechanisms to ensure that only authorized users access the database server. This includes using strong passwords, role-based access controls, and multi-factor authentication to limit user privileges. Encryption of data in motion using TLS instead of SSL. IP allow-listing to corporate offices to prevent random users from the internet from connecting to the database.

For a remediation strategy, always implement least privilege, where you don't give access to sensitive data to anyone, but only needed for people who actually are relevant, like system administrator, also providing minimum resources as possible. Another strategy could be MFA -Multi Factor Authentication, which is multiple steps to authenticate the user, and making sure that he or she is a real staff member, and real person, not like impersonating a hacker.